



Webfejlesztési keretrendszerek

9. gyakorlat

Dr. Jánki Zoltán Richárd

Biztonság, autentikáció és jogosultságkezelés



ALAPÉRTTELMEZETT 'TEST MODE' SZABÁLY

```

1 rules_version = '2';
2 service cloud.firestore {
3   match /databases/{database}/documents {
4     match /{document=**} {
5       **allow read, write: if true;**
6     }
7   }
8 }
  
```

A BaaS (Backend-as-a-Service) ALKALMAZÁSOK LEGGYAKORIBB BIZTONSÁGI HIBÁJA: A FEJLESZTŐ SOHA NEM CSERÉLI LE A NYITOTT SECURITY RULES-T.

AI ASSZISZTENSEK (Copilot, ChatGPT, Claude)

AI ASSZISZTENSEK (Copilot, ChatGPT, Claude)

AI ASSZISZTENSEK (Copilot, ChatGPT, Claude)

Itt egy működő rule! 🚀
(Biztonság? Nem az én feladatom.)

A "MŰKÖDIK" NEM EGYENLŐ A "BIZTONSÁGOS"-SAL ⚠️

EZ NEM FIREBASE-SPECIFIKUS: Supabase, Appwrite, REST API

HA NINCS AUTENTIKÁCIÓ ELLENŐRZÉS, BÁRKI BÁRMIT MÓDOSÍTHAT!

Autentikáció vs. autorizáció

AUTENTIKÁCIÓ VS AUTORIZÁCIÓ: A KÜLÖNBSÉG

AUTENTIKÁCIÓ (Authentication)

Ki vagy?

Személyazonosság igazolása (Verify identity)

A folyamat, amellyel a rendszer ellenőrzi a felhasználó kilétét.

Alapja (Based on):
Jelszók, Biometria,
Tokenek, SMS Kódok.

Példa: Bejelentkezés a weboldalra.



1. AZONOSÍTÁS (Identification)



2. ENGEDÉLYEZÉS (Authorization)



AUTORIZÁCIÓ (Authorization)

MIT TEHETSZ?

Jogosultságok meghatározása

A folyamat, amellyel a rendszer eldönti, mihez férhet hozzá az azonosított felhasználó.

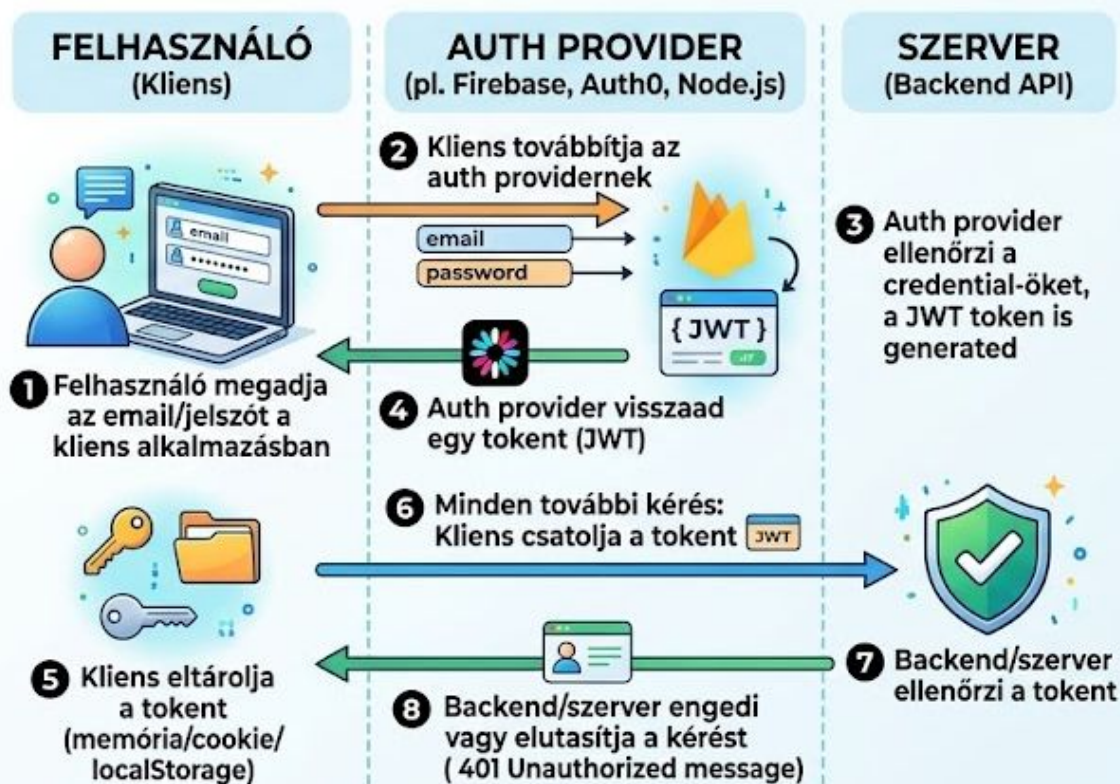
Alapja
Szerepkörök (Admin, User),
Hozzáférési Listák (ACL),
Szabályok.

Példa: Egy fájl megnyitása
vagy törlése.



Webes autentikáció működése

HOGYAN MŰKÖDIK A MODERN WEBES AUTENTIKÁCIÓ? (TOKEN-ALAPÚ FLOW)



MAGYARÁZAT ÉS FŐBB ELVEK

- ÁLTALÁNOS MECHANIZMUS, TECHNOLOGIÁTÓL FÜGGETLEN. (Firebase, Supabase, Auth0, saját Node.js backend mindezt követi.)
- SZERVER SOHA NEM BÍZIK VAKON A KLIENSBEN, MINDIG ELLENŐRZI A TOKEN.
- TOKEN (JWT - JSON WEB TOKEN): TARTALMAZZA A FELHASZNÁLÓ AZONOSÍTÓJÁT ÉS MÁS METADATA-T (PAYLOAD), DIGITÁLISAN ALÁÍRVA AZ ÉRVÉNYESSÉG ÉRDEKÉBEN.



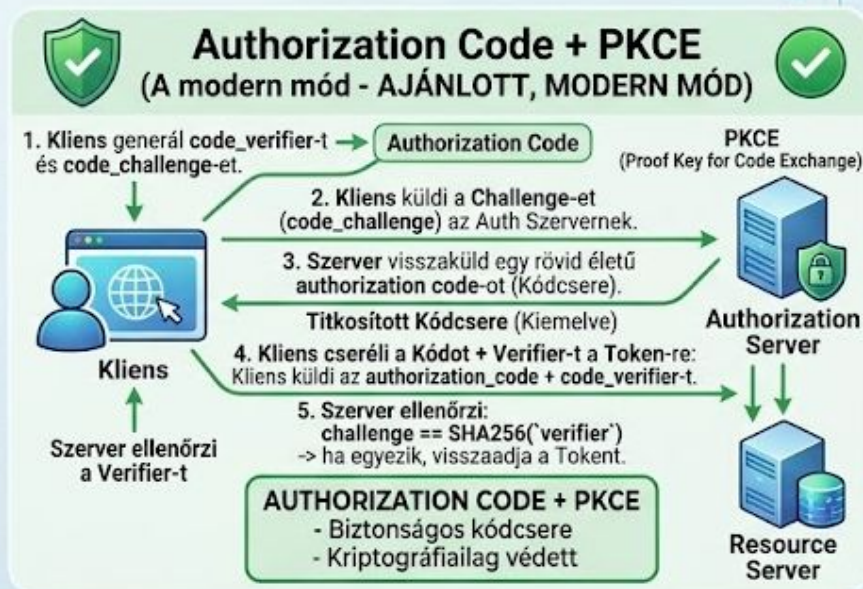
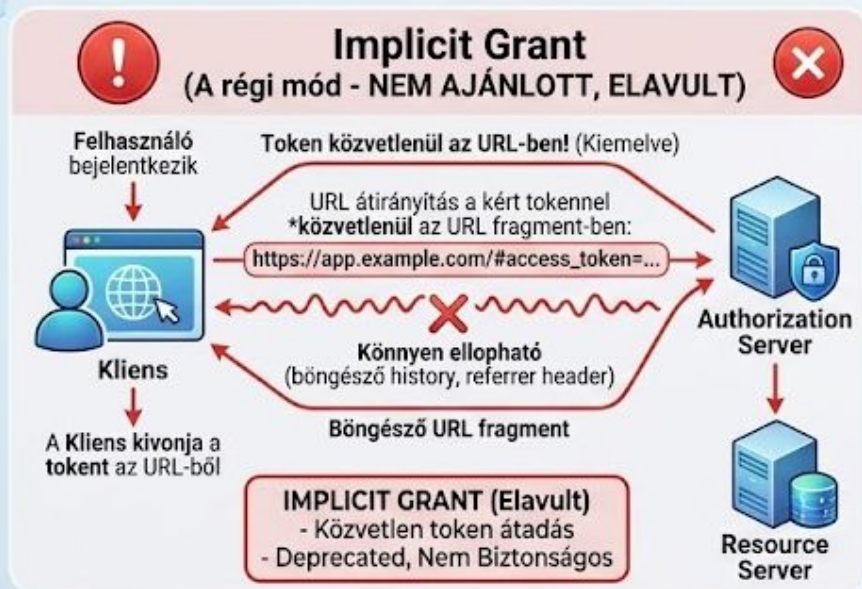
Token-típusok és tárolás

Tárolási mód	Előny	Hátrány	Mikor használjuk?
httpOnly	cookie XSS-védett (JS nem fér hozzá)	CSRF-védelem kell, bonyolultabb setup	Saját backend + szerver-oldali rendering
Memória (JS változó)	Legbiztonságosabb XSS ellen	Frissítéskor elvész, kell refresh token	SPA-k ideális választása
 localStorage	Egyszerű, perzisztens	XSS-sérülékeny (JS hozzáfér)	Csak ha nincs más, és alacsony a kockázat

- **BaaS megoldja SDK-n keresztül!**

OAuth 2.0 és SPA-k

OAuth 2.0 – AZ IPARÁGI SZABVÁNY ÉS BIZTONSÁGI EVOLÚCIÓ Áttekintés a Harmadik Feles Autentikációról



MIÉRT FONTOS: AI Generáció & Modern Alkalmazások (SPA)

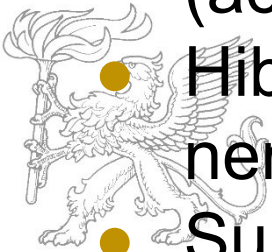
„Ha az AI Google login-t generál SPA-hoz és Implicit Grant-ot használ, az elavult. PKCE flow kell.”

Az Implicit Grant veszélyes a Single Page Applications (SPA) és mobilalkalmazások számára.
→ PKCE véd a 'Code Injection' és más támadások ellen.
→ Válasszunk biztonságos modern mintákat!



Login és Regisztráció űrlapja

- Reactive Forms használata (validáció, logika a TS-ben)
- Jelszó validáció: min. 8 karakter, legalább 1 szám + 1 nagybetű → custom validator
- Jelszó megerősítés: cross-field validáció (a két mező egyezik-e)
- Inline hibaüzenetek: aria-describedby-val kötve (accessibility!)
- Hibakezelés login-nál: „Hibás email vagy jelszó” — nem áruljuk el, melyik rossz (biztonsági okokból)
- Submit gomb disabled amíg a form invalid



Route Guard

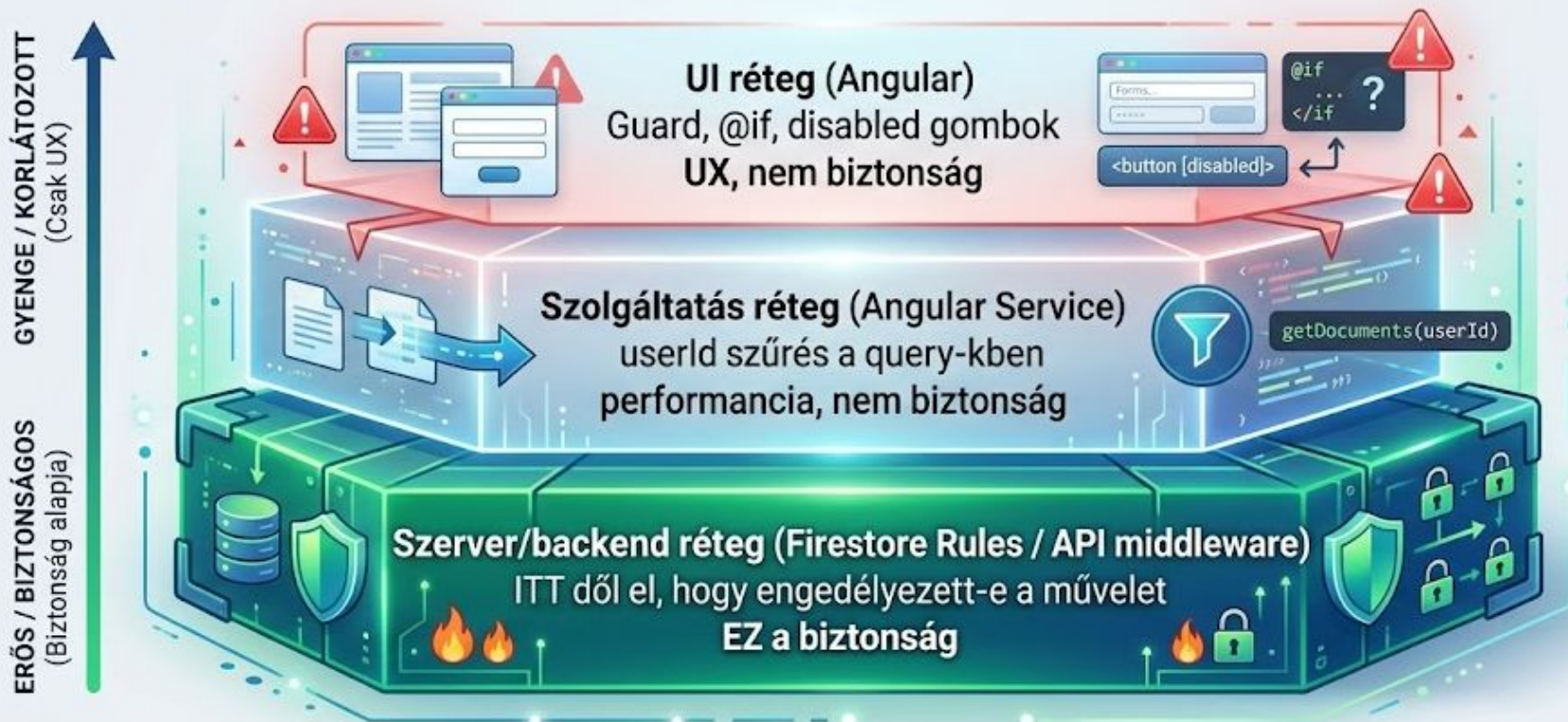
ROUTE GUARD-OK: MŰKÖDÉS ÉS FONTOSSÁG

ÚTVONAL-VÉDELEM ÉS HOZZÁFÉRÉS-SZABÁLYOZÁS



A tényleges biztonság

**A KLIENS MEGBÍZHATATLAN.
A SZABÁLYOK A SZERVEREN DŐLNEK EL.**





Biztonsági megoldások

Szempon	Firestore	Supabase	Saját backend
Autentikáció	Firestore Auth SDK	Supabase Auth (GoTrue)	Passport.js vagy custom JWT
Szabályok	Firestore Security Rules	Row Level Security (RLS) SQL-ben	Middleware
Token kezelés	SDK automatikusan	SDK automatikusan	Manuális JWT verifikáció
Guard	Route Guard	Route Guard	Route Guard

Gyakorlat

- Autentikáció megvalósítása
 - Login és regisztrációs oldal fejlesztése
 - Email-alapú autentikáció hozzáadása
- Jogosultságkezelés megvalósítása
 - Rule-ok definiálása (szerver oldal)
 - Route Guard-ok implementálása (kliens oldal)

